

22-C2 Detection - Command & Carol

Introduction



El TBFC está muy alerta desde la última serie de ataques de los subordinados del Rey Malhare. Están en alerta máxima ante cualquier cosa. Pero se están poniendo nerviosos; hay demasiado silencio. Sir Elfo del TBFC toma la iniciativa y propone buscar tráfico de Comando y Control utilizando el tráfico de red recopilado meticulosamente. La mayoría de los elfos del TBFC se oponen: ¡no tenemos tiempo para revisar tanto tráfico de red! Sir Elfo se ríe entre dientes: «No se preocupen, tengo una herramienta poderosa para ayudarnos». Les presento a RITA, Análisis de Amenazas de Inteligencia Real. Solo necesitamos convertir nuestro archivo PCAP a registros Zeek, ¡y RITA hará el resto! Cualquiera puede hacerlo, solo siga las tareas de hoy.

- Objetivos de aprendizaje
- Convertir un PCAP a registros Zeek
- Usar RITA para analizar registros Zeek
- Analizar el resultado de RITA

Answer the questions below

I have successfully started my target machine!

No answer needed

Detecting C2 with RITA

La magia de RITA

Real Intelligence Threat Analytics (RITA) es un framework de código abierto creado por Active Countermeasures. Su función principal es detectar la comunicación de comando y control (C2) mediante el análisis de capturas y registros de tráfico de red. Sus principales características son:

- Detección de balizas C2
- Detección de tunelización DNS
- Detección de conexiones largas
- Detección de exfiltración de datos
- Comprobación de fuentes de información sobre amenazas
- Calificación de conexiones por gravedad
- Mostrar el número de hosts que se comunican con una IP externa específica
- Mostrar la fecha y hora en que el host externo se detectó por primera vez en la red

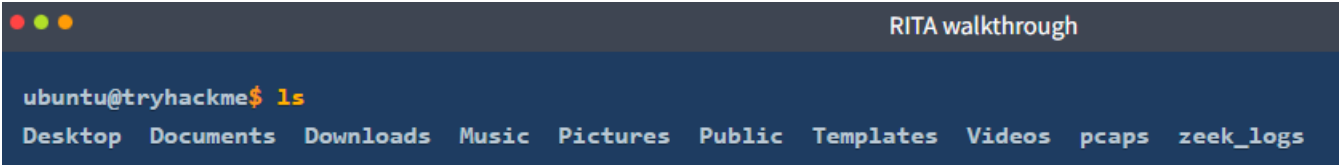
La magia de RITA reside en su análisis. Correlaciona varios campos capturados, como direcciones IP, puertos, marcas de tiempo y duraciones de conexión, entre otros. Basándose en el conjunto de datos normalizados y correlacionados, RITA ejecuta varios módulos de análisis que recopilan información como:

- Intervalos de conexión periódicos
- Número excesivo de consultas DNS
- FQDN largos
- Subdominios aleatorios
- Volumen de datos a lo largo del tiempo a través de HTTPS, DNS o puertos no estándar
- Certificados autofirmados o de corta duración
- IP maliciosas conocidas mediante referencias cruzadas con fuentes públicas de información sobre amenazas o listas de bloqueo

RITA solo acepta la entrada de tráfico de red como registros de Zeek. Zeek es una herramienta de monitorización de seguridad de red (NSM) de código abierto. Zeek no es un firewall ni un IPS/IDS; no utiliza firmas ni reglas específicas para actuar. Simplemente observa el tráfico de red a través de puertos SPAN configurados (utilizados para copiar el tráfico de un puerto a otro para su monitorización), tomas físicas de red o capturas de paquetes importadas en formato PCAP. Zeek analiza y convierte esta entrada en una salida estructurada y enriquecida. Esta salida puede utilizarse para la detección y respuesta a incidentes, así como para la búsqueda de amenazas. De fábrica, Zeek cubre dos de los cuatro tipos de datos NSM: datos de transacciones (registros resumidos de transacciones de la capa de aplicación) y datos de contenido extraído (archivos o artefactos extraídos, como ejecutables).

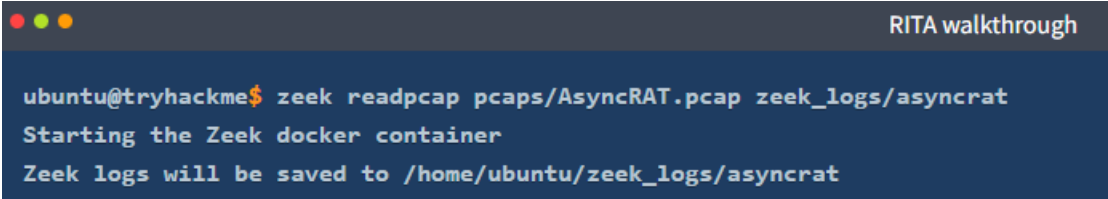
PCAP, Convierto Ye a registros de Zeek

¡Comencemos! Una característica interesante de Zeek es que puede convertir capturas de paquetes (PCAP) en registros estructurados. Si aún no lo ha hecho, abra la máquina virtual e inicie una terminal. Navegue al directorio de inicio del usuario conectado y muestre su contenido. Como se muestra en la terminal a continuación, podemos ver dos directorios llamados `pcaps` y `zeek_logs`.



El directorio pcaps contiene ejemplos de PCAP de incidentes reales recopilados del [blog](#) de Bradly Duncan. Tiene una magnífica colección de PCAP relacionados con malware que cubren amenazas reales.

El directorio zeek_logs contiene registros de Zeek. Estos se crearon analizando un archivo PCAP. Analicemos un PCAP nosotros mismos y observemos los registros de Zeek de salida. Usaremos el comando `zeek readpcap <pcapfile> <outputdirectory>` .



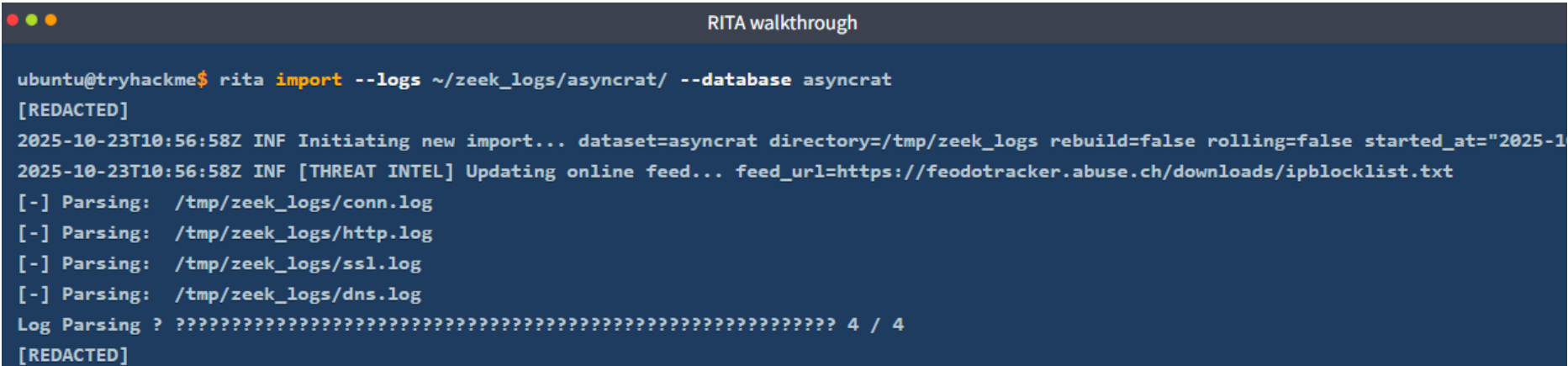
Examinemos los registros creados. Vaya a `/home/ubuntu/zeek_logs/asyncrat` y muestre su contenido. La salida debería ser similar a la que se muestra en la terminal a continuación.



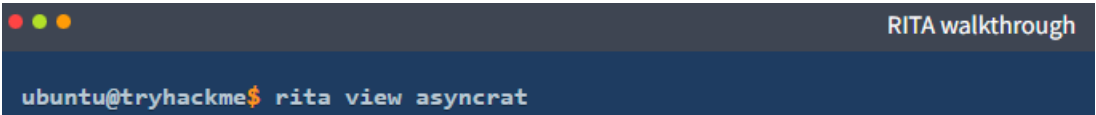
En la terminal anterior, podemos ver los diferentes registros de Zeek generados. Para usar RITA, no necesitamos saber qué contienen estos registros (aunque sus nombres son bastante autodescriptivos); sin embargo, si le interesa, puede usar `cat` para examinar su contenido. Puede encontrar más información en <https://docs.zeek.org/en/master/logs/index.html> si desea una descripción detallada.

Ahora, analice este RITA

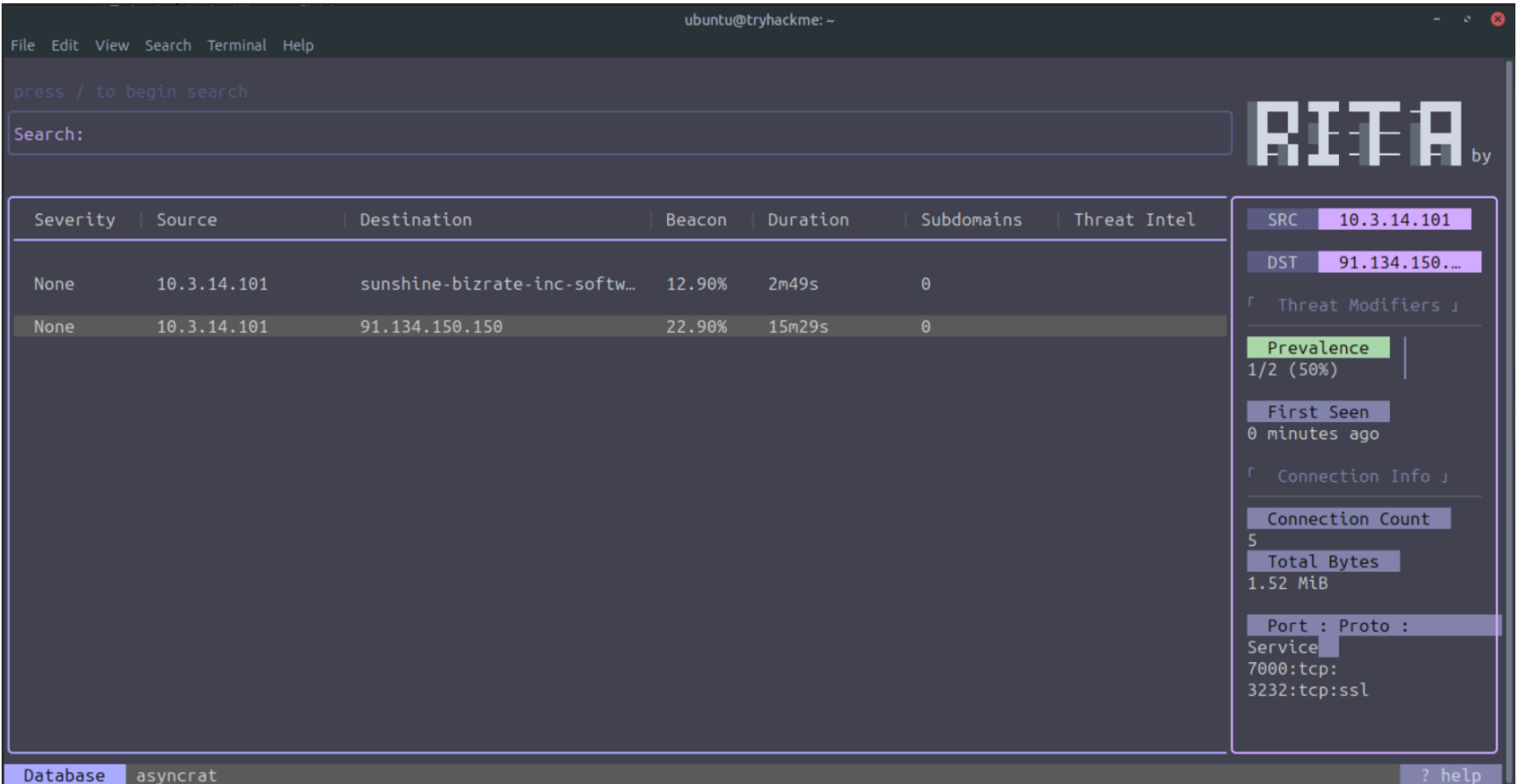
Ahora que hemos preparado los registros de Zeek, podemos importarlos a RITA y activar sus análisis. Introduzca el siguiente comando para importar los registros de Zeek y dejar que RITA realice su trabajo. Una vez introducido el comando, RITA analizará los registros importados. Como se ve en la terminal, se genera una gran cantidad de resultados. En el siguiente ejemplo, se ha redactado la salida de la terminal para mantenerla ordenada.



Ahora que RITA ha analizado nuestros datos, podemos ver los resultados introduciendo el comando `rita view <nombre-de-la-base-de-datos>` . Ahora introduzca el siguiente comando. Nota: Es importante considerar el tamaño del conjunto de datos. Los conjuntos de datos más grandes proporcionarán más información que los más pequeños. Además, los conjuntos de datos más pequeños son más propensos a generar falsos positivos. El que estamos utilizando es bastante pequeño, pero contiene suficientes datos para obtener un resultado inicial utilizable.



Luego de ingresar el comando, podremos ver una ventana de terminal estructurada con los resultados, como se muestra en la imagen de abajo.



La ventana de terminal muestra tres elementos: la barra de búsqueda, el panel de resultados y el panel de detalles.

Barra de búsqueda

Para buscar, necesitamos introducir una barra diagonal (/). A continuación, podemos introducir el término de búsqueda y restringir los resultados. La herramienta de búsqueda admite el uso de campos de búsqueda. Al introducir ? en el modo de búsqueda, podemos ver un resumen de los campos de búsqueda, junto con algunos ejemplos. La imagen a continuación muestra la ayuda de la herramienta de búsqueda. Para salir de la página de ayuda, vuelva a introducir ?. Pulse la tecla de escape ("esc") para salir de la función de búsqueda.

enter submit • esc cancel search • ctrl+x clear • ? toggle help

Search Examples

Filter by column:
severity:high
src:192.168.5.2
beacon:>80
threat_intel:true
duration:2h45m

Sort by column:
sort:severity-asc
sort:beacon-desc

Supported search columns:
• severity
• beacon
• duration
• subdomains

Supported Search Fields

Column	Field	Operators	Data Type
Severity	severity		critical high medium low
Source	src		IP address
Destination	dst		IP address or FQDN
Beacon Score	beacon	>,>=,<,<=	whole number
Duration	duration	>,>=,<,<=	string, ex:(2h45m)
Subdomains	subdomains	>,>=,<,<=	whole number
Threat Intel	threat_intel		true false

Multiple search criteria are separated by a space. For example:
src:192.168.88.2 dst:165.225.88.16 beacon:>=90 sort:duration-desc

Panel de resultados

El panel de resultados incluye información para cada entrada que puede ayudarnos a reconocer rápidamente posibles amenazas. Se incluyen las siguientes columnas:

- Gravedad:** Puntuación calculada según los resultados de los modificadores de amenaza (que se describen a continuación).
- IP/FQDN de origen y destino
- Probabilidad de baliza
- Duración de la conexión:** Las conexiones largas pueden ser indicadores de vulnerabilidad. La mayoría de los protocolos de capa de aplicación no tienen estado y cierran la conexión rápidamente después de intercambiar datos (las excepciones son SSH, RDP y VNC).
- Subdominios:** Conexiones a su bdominios con el mismo nombre de dominio. Si hay muchos subdominios, podría indicar el uso de una baliza C2 u otras técnicas de exfiltración de datos.
- Información sobre amenazas:** Lista las coincidencias en las fuentes de información sobre amenazas.

Podemos observar dos hallazgos interesantes: un FQDN que apunta a `sunshine-bizrate-inc-software[.]trycloudflare[.]com` y una IP `91[.]134[.]150[.]150` . Mueva las flechas del teclado para seleccionar la primera entrada. Debería ver información detallada en el panel derecho.

File Edit View Search Terminal Help

ubuntu@tryhackme: ~

press / to begin search

Search:

Severity	Source	Destination	Beacon	Duration	Subdomains	Threat Intel
None	10.3.14.101	sunshine-bizrate-inc-softw...	12.90%	2m49s	0	
None	10.3.14.101	91.134.150.150	22.90%	15m29s	0	

RITA

by Active Countermeasures

SRC10.3.14.101

DSTsunshine-bizrate-inc-software.trycloudflare.com

Threat Modifiers

Prevalence2/2 (100%)

First Seen1 minute ago

Rare Signature3c293bdf2a25c07559b560ba86debc77

Connection Info

Connection Count5

Total Bytes39.13 MiB

Port : Proto : Service443:tcp:ssl

Databaseasynocrat

? help

Panel de detalles

Además de Origen y Destino, tenemos dos categorías de información: Modificadores de Amenaza e Información de Conexión. Analicemos estas categorías con más detalle:

Modificadores de Amenaza

Estos son criterios para determinar la gravedad y la probabilidad de una amenaza potencial. Están disponibles los siguientes modificadores:

- Incompatibilidad de tipo MIME/URI:** Marca las conexiones donde el tipo MIME reportado en el encabezado HTTP no coincide con el URI. Esto puede indicar que un atacante está intentando engañar al navegador o a una herramienta de seguridad.

- **Firma Rara:** Indica patrones inusuales que los atacantes podrían pasar por alto, como una cadena de agente de usuario única que no se ve en ninguna otra conexión de la red.
- **Prevalencia:** Analiza el número de hosts internos que se comunican con un host externo específico. Un bajo porcentaje de hosts internos que se comunican con uno externo puede ser sospechoso.
- **Primera Vez Visto:** Comprueba la fecha en que se observó por primera vez un host externo en la red. Un nuevo host en la red tiene más probabilidades de representar una amenaza potencial.
- **Encabezado de host faltante:** Identifica las conexiones HTTP sin el encabezado de host, lo que suele ser un descuido de los atacantes o una señal de un sistema mal configurado.
- **Gran cantidad de datos salientes:** Marca las conexiones que envían una gran cantidad de datos fuera de la red.
- **Sin conexiones directas:** Marca las conexiones sin conexiones directas, lo que puede indicar una comunicación de comando y control más compleja u oculta.

Información de la conexión

Aquí se encuentran los metadatos de las conexiones e información básica de la conexión, como:

- Conteo de conexiones: Muestra el número de conexiones iniciadas entre el origen y el destino. Un número muy alto puede indicar actividad de baliza C2.
- Total de bytes enviados: Muestra la cantidad total de bytes enviados del origen al destino. Si este número es muy alto, podría indicar una exfiltración de datos.
- Número de puerto - Protocolo - Servicio: Si el número de puerto no es estándar, se requiere una investigación más profunda. La falta de SSL en la información del servicio también podría ser un indicador que requiere una investigación más profunda.

¿Qué es esto?

Ahora que hemos visto la apariencia de RITA, centrémonos en los resultados que muestra. Generalmente, estos resultados requieren atención. Incluso si la entrada no tiene una puntuación de gravedad alta, puede ser un indicador de vulnerabilidad. Utilizamos un conjunto de datos más pequeño, lo cual tiene algunas desventajas. Por ejemplo, el modificador de amenaza `First Seen` es relativamente bajo debido a la captura de paquetes en intervalos de tiempo cortos. Esto puede afectar la puntuación de gravedad.

En cualquier caso, podemos examinar las entradas y sus detalles para realizar nuestro propio análisis. Analicemos la primera entrada.

Severity	Source	Destination	Beacon	Duration	Subdomains	Threat Intel
None	10.3.14.101	sunshine-bizrate-inc-softw...	12.90%	2m49s	0	
None	10.3.14.101	91.134.150.150	22.90%	15m29s	0	

SRC10.3.14.101

DSTsunshine-bizrate-inc-software.trycloudflare.com

Threat Modifiers

Prevalence2/2 (100%)

First Seen1 minute ago

Rare Signature3c293bdf2a25c07559b560ba86debc77

Connection Info

Connection Count5

Total Bytes39.13 MiB

Port : Proto : Service443:tcp:ssl

Lo primero que observamos es el FQDN largo `sunshine-bizrate-inc-software[.]trycloudflare[.]com`. Una búsqueda rápida en VirusTotal indica que esta URL está marcada como maliciosa. ¡Fue fácil! Comprueba también la IP de destino de la segunda entrada. Afortunadamente, encontramos indicadores de compromiso conocidos de inmediato. Sin embargo, esto no siempre es así; los atacantes suelen cambiar su infraestructura y rotar las IP y los nombres de dominio. Por lo tanto, debemos investigar más a fondo cuando no tengamos un resultado positivo con indicadores de compromiso conocidos. Analicemos las entradas con más detalle.

Al examinar el panel de detalles, podemos ver más información. RITA incluyó el modificador de amenaza de `rare signature`. Esta inclusión indica que la combinación de ciertos parámetros (por ejemplo, detalles del certificado SSL) relacionados con esta conexión es poco común en comparación con el resto del tráfico HTTPS analizado. Las conexiones de malware o C2 suelen crear patrones de protocolo de enlace TLS únicos que difieren de los de los navegadores y clientes legítimos, lo que los hace destacar aunque la carga útil esté cifrada.

No hay mucho más que decir sobre la primera entrada, así que veamos la segunda:

- Según VirusTotal, la IP es maliciosa.
- La duración de la conexión es bastante larga.
- Los puertos mencionados no son estándar.

Esta información requiere una investigación más profunda. Puede aprovechar la información obtenida y revisar los registros de Zeek y el archivo PCAP. Esto queda fuera del alcance de esta guía, pero no dude en investigarlo y obtener información. Solo tenga cuidado, ya que algunos PCAP pueden contener archivos, dominios e IP maliciosos que aún están en uso.

Cada uno hará su parte.

Ahora que todos han revisado el manual, ¡vamos a buscar esos "malrabbits"! Nos hemos esforzado mucho en capturar el tráfico de red. Analice el archivo `~/pcaps/rita_challenge.pcap` con RITA y responda las preguntas a continuación. Nota: Siga los pasos aprendidos para procesar el PCAP y analizarlo con RITA.

Answer the questions below

How many hosts are communicating with **malhare.net**?

Respuesta: 6

Severity	Source	Destination
High	10.0.0.13	rabbithole.malhare.net
High	10.0.0.15	rabbithole.malhare.net
Low	10.0.0.14	rabbithole.malhare.net
Low	10.0.0.12	rabbithole.malhare.net
None	10.0.0.11	rabbithole.malhare.net
None	10.0.1.5	192.0.2.53
None	10.0.0.10	rabbithole.malhare.net
None	10.0.0.13	c2.thm-labs.net

Which Threat Modifier tells us the number of hosts communicating to a certain destination?

respuesta: prevalence

What is the highest number of connections to **rabbithole.malhare.net**?

Respuesta: 40

Severity	Source	Destination	Beacon	Duration	Subdomains	Threat Intel
High	10.0.0.13	rabbithole.malhare.net	97.70%	17m8s	0	
High	10.0.0.15	rabbithole.malhare.net	97.70%	21m1s	0	
Low	10.0.0.14	rabbithole.malhare.net	70.60%	1s	0	
Low	10.0.0.12	rabbithole.malhare.net	68.60%	15m1s	0	
None	10.0.0.11	rabbithole.malhare.net	64.40%	12m59s	0	
None	10.0.1.5	192.0.2.53	31.20%	0s	0	
None	10.0.0.10	rabbithole.malhare.net	49.80%	10m52s	0	
None	10.0.0.13	c2.thm-labs.net	45.20%	0s	0	

SRC10.0.0.15

DSTrabbithole.malhare.net

Threat Modifiers

Prevalence6/10 (60%)

First Seen1 hour ago

Connection Info

Connection Count40

Total Bytes13.35 KiB

Port : Proto : Service80:tcp:http

Which search filter would you use to search for all entries that communicate to **rabbithole.malhare.net** with a **beacon score** greater than 70% and sorted by **connection duration (descending)**?

Respuesta: dst:rabbithole.malhale.net beacon>=70 sort:duration-desc

siempre iniciar con /

dst:rabbithole.malhale.net beacon>=70 sort:duration-desc

by Active Countermeasures

Severity	Source	Destination	Beacon	Duration	Subdomains	Threat Intel
High	10.0.0.13	rabbithole.malhare.net	97.70%	17m8s	0	
High	10.0.0.15	rabbithole.malhare.net	97.70%	21m1s	0	
Low	10.0.0.14	rabbithole.malhare.net	70.60%	1s	0	
Low	10.0.0.12	rabbithole.malhare.net	68.60%	15m1s	0	
None	10.0.0.11	rabbithole.malhare.net	64.40%	12m59s	0	
None	10.0.1.5	192.0.2.53	31.20%	0s	0	
None	10.0.0.10	rabbithole.malhare.net	49.80%	10m52s	0	
None	10.0.0.13	c2.thm-labs.net	45.20%	0s	0	

SRC10.0.0.13

DSTrabbithole.malhare.net

Threat Modifiers

Prevalence6/10 (60%)

First Seen1 hour ago

Connection Info

Connection Count31

Total Bytes10.37 KiB

Port : Proto : Service80:tcp:http

Which port did the host 10.0.0.13 use to connect to **rabbithole.malhare.net**?

respuesta: 80

High	10.0.0.13	rabbithole.malhare.net	97.70%	17m8s	0
High	10.0.0.15	rabbithole.malhare.net	97.70%	21m1s	0
Low	10.0.0.14	rabbithole.malhare.net	70.60%	1s	0
Low	10.0.0.12	rabbithole.malhare.net	68.60%	15m1s	0
None	10.0.0.11	rabbithole.malhare.net	64.40%	12m59s	0
None	10.0.1.5	192.0.2.53	31.20%	0s	0
None	10.0.0.10	rabbithole.malhare.net	49.80%	10m52s	0
None	10.0.0.13	c2.thm-labs.net	45.20%	0s	0

DSTrabbithole.malhare.net

Threat Modifiers

Prevalence6/10 (60%)

First Seen1 hour ago

Connection Info

Connection Count31

Total Bytes10.37 KiB

Port : Proto : Service80:tcp:http

encontramos el pcap a utilizar

```
ubuntu@tryhackme:~$ cd pcaps/
ubuntu@tryhackme:~/pcaps$ ls
AsyncRAT.pcap  IcedID.pcap  Pikabot.pcap  rita_challenge.pcap
ubuntu@tryhackme:~/pcaps$
```

leemos el contenido y lo importamos a otro directorio

```
ubuntu@tryhackme:~$ zeek readpcap pcaps/rita_challenge.pcap zeek_logs/rita_challenge
Starting the Zeek docker container
Zeek logs will be saved to /home/ubuntu/zeek_logs/rita_challenge
```

verificamos que el directorio se haya creado

```
ubuntu@tryhackme:~$ cd zeek_logs/
ubuntu@tryhackme:~/zeek_logs$ ls
Example-5-2020-08-18-Emotet-infection-with-Qakbot.pcap.zip  asynccrat  pikabot  rita_challenge
```

importamos el contenido a rita

```
ubuntu@tryhackme:~$ rita import --logs ~/zeek_logs/rita_challenge/ --database rita_challenge
[+] up 2/2
  ✓ Container rita-clickhouse Healthy
  ✓ Container rita-syslog-ng Running
[+] 2/2t 2/2
  ✓ Container rita-syslog-ng Running
  ✓ Container rita-clickhouse Running
Container rita-clickhouse Waiting
Container rita-clickhouse Healthy
Container rita-rita-run-e1fe9df6d44d Creating
Container rita-rita-run-e1fe9df6d44d Created
2025-12-24T20:52:23Z INF Initiating new import... dataset=rita_challenge directory=/tmp/zeek_logs rebuild=false rolling=false star
3"
[-] Parsing: /tmp/zeek_logs/conn.log
[-] Parsing: /tmp/zeek_logs/http.log
[-] Parsing: /tmp/zeek_logs/dns.log
Log Parsing 🧙🏽 ||||| 3 / 3
2025-12-24T20:52:24Z INF Finished Parsing Logs! 🧙🏽 elapsed_time=529.462671ms parsing_began=1766609543 parsing_finished=1766609544
```

🧙🏽 Seasoning SSL connections 🧙🏽 100%

🧙🏽 Seasoning HTTP connections 🧙🏽 100%

✅ Sifting IP connections...

2025-12-24T20:52:24Z INF Finished Seasoning Logs! 🧙🏽 elapsed_time=220.558824ms seasoning_began=1766609544 seasoning_finished=1766609544

SNI Connection Analysis 🧙🏽 100%

IP Connection Analysis 🧙🏽 100%

DNS Analysis 🧙🏽 100%

2025-12-24T20:52:26Z INF Finished Analysis! 🧙🏽 analysis_began=1766609544 analysis_finished=1766609546 elapsed_time=1.382543426s

2025-12-24T20:52:26Z INF Finished Modification! 🧙🏽 elapsed_time=33.413803ms modification_began=1766609546 modification_finished=1766609546

2025-12-24T20:52:26Z INF Finished Importing Hour Chunk day=0 elapsed_time=2.288442231s hour=0

2025-12-24T20:52:26Z INF 🧙🏽🧙🏽 Finished Import! 🧙🏽🧙🏽 elapsed_time=2.7s

[+] stop 1/1

✓ Container rita-rita-1 Stopped

visualizaamos el archivo

```
ubuntu@tryhackme:~$ rita view rita_challenge
```

obtenemos la vista del archivo

press / to begin search

Search:

RITAby Active Countermeasures0

Severity	Source	Destination	Beacon	Duration	Subdomains	Threat Intel
High	10.0.0.13	rabbithole.malhare.net	97.70%	17m8s	0	
High	10.0.0.15	rabbithole.malhare.net	97.70%	21m1s	0	
Low	10.0.0.14	rabbithole.malhare.net	70.60%	1s	0	
Low	10.0.0.12	rabbithole.malhare.net	68.60%	15m1s	0	
None	10.0.0.11	rabbithole.malhare.net	64.40%	12m59s	0	
None	10.0.1.5	192.0.2.53	31.20%	0s	0	
None	10.0.0.10	rabbithole.malhare.net	49.80%	10m52s	0	
None	10.0.0.13	c2.thm-labs.net	45.20%	0s	0	

SRC10.0.0.13

DSTrabbithole.malhare.net

Threat Modifiers

Prevalence6/10 (60%)

First Seen1 hour ago

Connection Info

Connection Count31

Total Bytes10.37 KiB

Port : Proto : Service80:tcp:http

Databaserita_challenge? help